

ZKP Enabled Identity and Reputation Verification in P2P Marketplaces

Jan Kalbantner, Konstantinos Markantonakis, Darren Hurley-Smith
Information Security Group
Royal Holloway University of London
 Egham, United Kingdom
 {jan.kalbantner.2018,k.markantonakis,darren.hurley-smith}@rhul.ac.uk

Carlton Shepherd
School of Computing
Newcastle University
 Newcastle-upon-Tyne, United Kingdom
 carlton.shepherd@ncl.ac.uk

Abstract—In the realm of Distributed Ledger Technology, privacy and regulatory challenges loom large for marketplaces. Regulation requires to conduct Know Your Customer (KYC) procedures to verify the identity of participants, while privacy concerns necessitate the protection of personal data. Current approaches to KYC are inefficient and are potentially even harmful to privacy due to centralization and data exposure. This paper proposes a zero-knowledge proof enabled KYC scheme, utilizing Soulbound Tokens (SBT) to create a discreet, compliant, and secure KYC process. We present a privacy-preserving mechanism that shares only essential information while adhering to Self-Sovereign Identity (SSI) principles, placing users in the full control of their data. The proposed scheme further introduces the usage of SBTs for reputation to incentivize good conduct and build trust within marketplaces.

Index Terms—blockchain, zero-knowledge proof, privacy, DLT, reputation, marketplace

I. INTRODUCTION

Distributed Ledger Technology (DLT) enables secure and efficient Peer-to-Peer (P2P) interactions [1], [2] but its transparency challenges privacy and confidentiality, especially in marketplaces requiring participant anonymity [3]. In such environments, including collateralized P2P marketplaces, public visibility of identities and transaction details can deter participation due to concerns over asset security and potential targeting by malicious actors. Therefore, privacy-preserving mechanisms are essential to ensure marketplace integrity and encourage user engagement.

The need to comply with jurisdictional Anti-Money Laundering/Counter-Terrorism Financing (AML/CTF) guidelines further complicates the challenge of balancing privacy with identity verification. Diverse regional regulations, including the EU's AML Directives [4], [5], the US AMLA [6], and the FATF Travel Rule [7], add complexity for Virtual Asset Service Providers (VASPs) and hinder DeFi adoption [8], [9].

Moreover, reliance on Certification Authorities (CAs) for stringent KYC compliance poses challenges such as inconsistent practices, economic burdens for VASPs, and potential legal repercussions [10]. Cumbersome identification processes hinder user interaction and market efficiency, while sharing personal data with unknown entities raises trust concerns. The UN's Digital Strategy 2022-2025 [11] highlights the need for privacy-preserving mechanisms like Decentralized Identifiers

(DIDs) due to vulnerabilities in centralized identity systems, including data breaches and lack of user control [12], [13]. DIDs distribute data, empowering users with ownership and transparency [14], [15], [16]. Soulbound Tokens (SBTs), a type of non-transferable NFT [17], enhance DIDs by creating tamper-proof links to personal attributes and affiliations [14]. Combining SBTs with Zero-Knowledge Proofs (ZKPs) allows users to prove KYC compliance without revealing sensitive information, ensuring privacy and confidentiality [10], [18].

Despite the transparency and decentralization benefits of DLT, public visibility of transactions threatens privacy and confidentiality [19], [1], [2]. Existing KYC procedures suffer from limitations such as centralized data storage, repetitive verification, and lack of user control [8], [9]. Table I compares our proposed solution with existing approaches based on key design goals, including technology agnosticism, confidential transactions and document storage, unlinkability, untraceability, and applicability for reputation validation. We consider the following design goals:

- [DG1] **Technology agnostic:** The solution is flexible and not restricted to a specific technology, such as a particular ZKP scheme or blockchain.
- [DG2] **Confidential transaction:** Ensures transactions are confidential and not publicly visible through encryption or zero-knowledge proofs.
- [DG3] **Confidential document storage:** Ensures documents are stored confidentially and are not publicly visible, including encryption of documents.
- [DG4] **Unlinkability and untraceability:** Ensures credentials and documents cannot be linked or traced to a specific user by an adversary, using selective disclosure in credential verification.
- [DG5] **Usable for reputation validation:** Can be used to validate reputation and identities.

This paper contributes a novel approach that strikes a balance between privacy preservation and regulatory compliance for KYC. We introduce the novel concept of integrating VC (Verifiable Credentials) and SBT to immutably link identities with reputation tokens. Further, we develop a decentralized reputation management mechanism to foster accountability within marketplaces. The proposed techniques of employing

Work	DG1	DG2	DG3	DG4	DG5
Abraham et al. [20]	●	●	●	●	○
Aydar et al. [18]	○	○	●	●	○
Niya et al. [21]	●	○	○	○	○
Pauwels et al. [8]	○	●	●	○	●
Rathee et al. [22]	○	●	○	●	○
Kim & Ryou [15]	○	●	○	●	○
Hou et al. [23]	○	●	○	○	○
Singh et al. [24]	○	●	●	●	○
Zhang & Lee [25]	●	○	○	○	●
Biryukov et al. [26]	○	●	○	○	○
Our proposal	●	●	●	●	●

TABLE I: Evaluating solutions against design goals.

ZKP to selectively reveal credentials combined with our reputation scheme enable building trust while prioritizing user control over personal data through SSI principles. Our contributions include:

- SBTs to connect identities and reputations, enhancing accountability
- Decentralized identity and reputation token validation management for marketplaces
- Decentralized credential storage and selective disclosure of data enhanced by zero-knowledge technology

The rest of the paper is organized as follows. In Section 2, we present the technologies and backgrounds used within this paper. Section 3 presents the scheme, while Section 4 presents the security, privacy and complexity analysis. Followed by Section 5, which gives an overview of related work. Finally, in Section 6, we conclude the paper.

II. PRELIMINARIES

We align our design around the principles of SSI and DID, emphasizing personal ownership and self-managed control of one's identity. DIDs are identities managed in a decentralized manner and are not tied to a central authority, forming the backbone of SSI systems [20]. These DIDs are registered on decentralized systems such as DLT (e.g. blockchain) and associated with a public key, enabling participants to prove their identity and authentication while keeping their personal information private. For universal adoption, compliance with standards set by the World Wide Web Consortium (W3C) [16], Decentralized Identity Foundation (DIF) [27], and legal frameworks including the EU's GDPR [28], EU's AMLD 4 [4]/5 [5], the US AMLA of 2020 [6], global FATF recommendations [7], and other pertinent laws and regulations is crucial for DIDs.

To enhance SSI systems, VCs act as cryptographically secured digital representations of information that can be independently verified. Issued by authorized entities (e.g. governments), VCs contain details about individuals' attributes, qualifications, or permits. They can be connected to a DID and verified using the issuer's public key, preserving privacy. Storing VCs, DIDs, and private keys within a digital wallet enables seamless presentation to verifiers and efficient management. The concept of SBTs [14] links DIDs to an immutable status. SBTs, as non-transferable NFTs, can be revoked when necessary. If a user loses, destroys, or has their SBT revoked,

obtaining a new one requires interaction with the initial issuing entity. SBTs are ideal for expressing commitments, credentials, and affiliations, with significant applications in connecting to DIDs. By leveraging pre-verified VCs during KYC procedures, users avoid redundant verifications while maintaining their KYC status attached to their unique identity in a non-transferable manner.

Historically, reputation schemes based on feedback [29] relied on user ratings that could be easily manipulated. Blockchain technology, however, has enabled the development of distributed reputation systems that address these challenges effectively [25], [30], [31]. In this paper, we introduce the use of SBTs as reputation tokens to foster positive behaviour and build trust within virtual environments. Specifically, we use marketplace reputation tokens, referred to as MRT. Both centralized and decentralized marketplaces benefit from effective reputation tokens, empowering participants to assess peers' reliability before transactions. SBTs also serve as tokenized proof of KYC verification, securely linked to a DID and MRT. This retains KYC validation and marketplace reputation within the original identity without transferability. Standard KYC processes typically involve three steps: validating client details like names, dates of birth, addresses, and VCs; performing KYC at simplified, basic, or advanced levels based on risk factors, which might include PEP (Politically Exposed Person) scans, media screening, watchlist examinations, credit card statement analysis, and reference checks; and continuous monitoring, which includes reporting suspicious activities and alerting authorities as required [32], [4], [5].

To increase security and privacy, we incorporate ZKPs, which discreetly handles inputs and outputs. ZKPs are cryptographic protocols enabling one party (prover $\mathcal{P}$) to demonstrate to another party (verifier $\mathcal{V}$) possession of certain knowledge or a secret value (witness w), while preserving confidentiality. Specifically, ZKP allows $\mathcal{P}$ to convince $\mathcal{V}$ that a given input x is true without disclosing sensitive information beyond the statement's validity for an efficient probabilistic algorithm S (the simulator) [33]: $True|False \leftarrow S(x, w)$. ZKP technology includes the following properties [33], [34], [35]:

- *Completeness*: If the statement is true ($True \leftarrow S(x)$) and both parties ($\mathcal{P}, \mathcal{V}$) follow the protocol correctly, $\mathcal{V}$ will be convinced that $\mathcal{P}$ has the required knowledge.
- *Soundness*: If the statement is false ($False \leftarrow S(x)$), no malicious actor (fake prover $\mathcal{P}$) can produce a convincing proof for an honest $\mathcal{V}$.
- *Zero-knowledge*: $\mathcal{V}$ gains no additional knowledge about the secret value w beyond its existence ($True \leftarrow S(x, w)$). Any new information learned during proof generation can be acquired without interacting with $\mathcal{P}$.
- *Non-transferability*: Valid ZKPs cannot be transferred from one $\mathcal{V}$ to another without knowledge of the secret w , preventing an adversary from reusing an existing proof π .
- *Unforgeability*: An adversary cannot generate a proof π that would deceive an honest verifier $\mathcal{V}$ about the existence of a non-existent secret value w .

For evaluating ZKP systems, we analysed several common schemes based on SNARK (succinct non-interactive arguments of knowledge), SNORK (succinct non-interactive oecumenical arguments of knowledge), STARK (scalable transparent arguments of knowledge), Bulletproofs (BP), and DARKs (diophantine arguments of knowledge). Table II provides an overview of different ZKP schemes and their properties [36], [37], [38], [39], [40], [41], [42], [43], [44], [45]. The table includes message or communication complexity (proof size π), algorithmic complexity for the verifier $\mathcal{V}$ and prover $\mathcal{P}$, and the cryptographic assumptions (e.g. KOE (knowledge of exponent), AGM (algebraic group model), DL (discrete logarithm), CRHF (collision-resistant hash function), RSA) underpinning these systems' security. Additionally, it addresses the need for a trusted setup (TS) and post-quantum (PQ) security. The choice of technology for a ZKP system depends on specific requirements.

Method	Message complexity (π size)	$\mathcal{V}$ algorithmic complexity:	$\mathcal{P}$ algorithmic complexity:	TS needed?	PQ secure?	Cryptographic assumption
SNARKs [41]	$O(1)$	$O(1)$	$O(n \log n)$	Yes	No	q-type, KOE
SNORKs [38], [40]	$O(1)$	$O(1)$	$O(n \log n)$	Yes	No	AGM
Bulletproofs [45]	$O(\log n)$	$O(n)$	$O(n \log n)$	No	No	DL
STARKs [43]	$O(\text{polylog } n)$	$O(\text{polylog } n)$	$O(n \text{ polylog } n)$	No	Yes	CRHF
DARKs [36], [37]	$O(2 \log n)$	$O(3 \log n)$	$O(n \log n)$	No	No	RSA group + class group

TABLE II: Candidate zero-knowledge systems.

III. IDENTITY AND REPUTATION VERIFICATION IN P2P MARKETPLACES

A. System Model

In current marketplaces, KYC procedures and marketplace reputation are handled separately. Users must undergo identity verification for each marketplace and build their reputation individually, even if they trade the same products. Reputation is not transferable between marketplaces, resulting in diverse, non-interoperable systems. For marketplaces, reputation is crucial in determining user trustworthiness. After successful verification, users receive specific authorizations to use the marketplace based on their verified identity. Currently, data is mostly stored in centralized databases to manage validated information. In decentralized scenarios, privacy is more scrutinized as verification must be conducted publicly on the blockchain. User information must be encrypted or protected with ZKP to maintain privacy. However, due to a lack of standardization, this process does not always ensure the accuracy of user-provided information. Current approaches are inefficient and pose privacy risks. To address these challenges, we use DIDs to ensure trustworthy user information and SSI principles to keep data under user control. Once a user has a verified identity, they only need to prove their identity to access a marketplace. The SBT remains in the wallet, proving ownership without needing to be transferred. Consequently, VCs do not need to be transferred to each new marketplace. A verified user can then obtain multiple MRT based on their identity (e.g. SBT) without undergoing lengthy verification processes again.

Only the KYC issuer can access user information, while the data is stored decentrally within an InterPlanetary File System (IPFS) [12], [13]. Users control access to their VCs within IPFS and can revoke access at any time, ensuring full control over their data and deciding who can access it.

B. System Architecture

The proposed scheme, illustrated in Figure 1, comprises the following key components:

- **Participants:** Individuals or entities engaging in marketplace trading activities. Each trading activity is linked to a unique DID.
- **CA:** Trusted third parties that verify participant identities and issue SBTs. CAs ensure participants meet KYC requirements and are eligible for SBTs.
- **Marketplace:** The platform where participants trade goods and services after identity verification. It issues MRTs and facilitates trading activities.
- **Blockchain:** An immutable ledger managing DIDs, SBTs, and MRTs. It registers and verifies transactions and stores relevant data.
- **Data Storage:** Secure storage for sensitive data, such as personal data, financial details, and transaction records. For decentralization, IPFS is used to store the data.

The key processes involved in the proposed scheme are described in the following subsections.

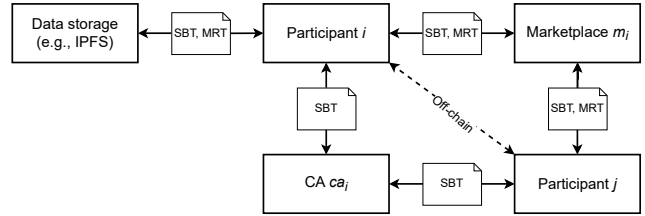


Fig. 1: High-level overview of the proposed scheme.

1) Identity verification

In our scenario, we define three levels of KYC to meet various compliance needs. Each level is designed to comply with laws and regulations aimed at preventing money laundering, terrorist financing, and other illegal financial activities. Specific regulations can vary by country [32], [21], but they generally align with international standards set by bodies like the FATF [7]. Financial institutions and other entities must comply with these laws and implement KYC procedures to avoid penalties and ensure the integrity of the financial system [32], [4], [5]. Level 1 (basic KYC): Establishes and verifies essential customer information, adhering to AML laws and Customer Identification Program (CIP) requirements [6]. Essential information includes first name, last name, address, date of birth, and can be verified with VCs such as passports, driving licences, and government-issued IDs: $sbt_{p_i}^{L1} \leftarrow \text{verify}(vc_{p_i})$. Level 2 (intermediate KYC): Incorporates occupational details, source of income, and transaction patterns to meet enhanced due diligence (EDD) expectations. This level ensures

that customers who do not pose a high risk are compliant: $sbt_{p_i}^{L2} \leftarrow sbt_{p_i}^{L1} \wedge \text{verify}(\text{employment} \wedge \text{source of wealth})$. Level 3 (enhanced KYC): Includes thorough screening procedures for high-risk clients (e.g. high net worth individuals, or people from high-risk countries), addressing strict AML and CTF obligations: $sbt_{p_i}^{L3} \leftarrow sbt_{p_i}^{L2} \wedge \text{verify}(\text{additional information})$.

2) Reputation Scoring

Trustworthiness and reliability assessments are crucial in off-chain transactions. We propose a three-tier reputation scoring mechanism based on KYC status and transactional records.

Level 1 reputation ($mrt_{p_i}^{L1}$): Requires completion of KYC level 1 ($sbt_{p_i}^{L1}$), a minimum number of transactions ($\mathcal{T} \geq 10$), and an account active for at least 1 month. This ensures a verified track record, countering Sybil attacks [46], [47], [48], [49]. Calculated as: $mrt_{p_i}^{L1} \leftarrow sbt_{p_i}^{L1} \wedge \mathcal{T} \geq 10 \wedge mrt_{p_i} \geq 1, \text{month}$. Level 2 reputation ($mrt_{p_i}^{L2}$): Builds on Level 1, requiring KYC level 2 ($sbt_{p_i}^{L2}$), at least 100 transactions, and over 95% positive feedback with an active account for at least 6 months. This encourages good conduct and builds trust: $mrt_{p_i}^{L2} \leftarrow mrt_{p_i}^{L1} \wedge sbt_{p_i}^{L2} \wedge \mathcal{T} \geq 100 \wedge \frac{95}{100} \wedge mrt_{p_i} \geq 6, \text{months}$. Level 3 reputation ($mrt_{p_i}^{L3}$): Builds on Levels 1 and 2, requiring KYC level 3 ($sbt_{p_i}^{L3}$) and a total trade volume of at least 100,000 USD within 3 months. This ensures substantial and verified trading activity: $mrt_{p_i}^{L3} \leftarrow mrt_{p_i}^{L2} \wedge sbt_{p_i}^{L3} \wedge TV \geq 100,000, \text{USD} \wedge \mathcal{T} \geq 3, \text{months}$.

This hierarchical structure allows participants to build reputation scores by meeting increasingly stringent criteria, enhancing trust and credibility. It incentivizes transparency, discourages malicious behaviour, and mitigates the risk of system manipulation, such as Sybil attacks [50]. Each new participant undergoes rigorous scrutiny before joining a marketplace, reducing risks of consensus manipulations, network congestion, and financial losses, fostering a secure environment based on mutual trust and accountability. However, MRTs, being based on SBTs, are non-transferable and must be requested for each marketplace. Marketplaces may choose to accept MRTs from others if they trust their evaluation and verification processes.

C. Processes

Figure 2 illustrates the processes and relationships between entities, showing four key processes: SBT registration, MRT registration, trade initialization, and trade finalization. A new participant, p_i , wishing to trade on marketplace m_i , must first register. The CA ca_i analyzes p_i 's credentials, verifies the VC vc , and issues the SBT sbt_{p_i} .

Before p_i can initiate the process, they must create a wallet, w_{p_i} , which stores the SBT, sbt_{p_i} . This wallet also safeguards p_i 's private key, pk_{p_i} , for signing transactions, and the public key, k_{p_i} , for verifying signatures. Additionally, w_{p_i} transmits vc_{p_i} to an IPFS, $ipfs_i$, storing a copy as $vc_{p_i}^{ipfs}$. The information in $vc_{p_i}^{ipfs}$ is encrypted with a separate key, $k_{p_i}^{ipfs}$, also stored in w_{p_i} . To enhance privacy, selective disclosure mechanisms can reveal only necessary information [51]. A notable implementation is the Camenisch-Lysyanskaya (CL) signature scheme [52], which enables selective information disclosure during signature verification and is probabilistically secure under the strong RSA assumption.

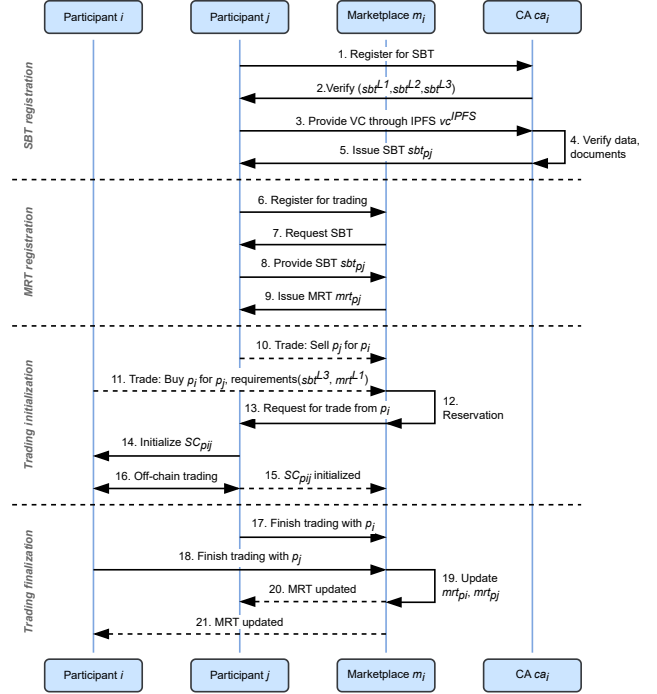


Fig. 2: Process flowchart of the proposed scheme.

1) SBT registration

The registration process, Algorithm 1, begins when p_i seeks to register for sbt_{p_i} issued by ca_i . For this purpose, p_i sends the encrypted VC, $vc_{p_i}^{ipfs}$, along with the key, $k_{p_i}^{ipfs}$, to ca_i . The KYC issuer ca_i then conducts a comprehensive background check to authenticate p_i 's credentials, adhering to the applicable KYC regulations and requirements. After verifying p_i , ca_i issues sbt_{p_i} and registers it on the blockchain. Based on the provided information, ca_i determines the KYC level of p_i —either $sbt_{p_i}^{L1}$, $sbt_{p_i}^{L2}$, or $sbt_{p_i}^{L3}$ —and issues the corresponding sbt_{p_i} . The SBT is linked exclusively to p_i 's account, ensuring it cannot be transferred or modified by others. The specifics of sbt_{p_i} are documented on the blockchain, establishing a permanent record of p_i 's registration and identity verification within m_i .

Algorithm 1: SBT registration

Input: p_i, ca_i **Output:** $result, sbt_{p_i}$
 $data = [], result = \text{True}, \text{False};$
 $data \leftarrow \text{receiveData}(vc_{p_i}^{ipfs}, k_{p_i}^{ipfs})$; CA receives data
while data **do**
 $result \leftarrow \text{verify}(vc_{p_i}^{ipfs})$; Verif. of VC
 if result $\leftarrow \text{True}$ **then**
 $sbt_{p_i} \leftarrow \text{issueSBT}(p_i)$; Issue of SBT
 end
 return result $\leftarrow \text{False};$
end
 register(sbt_{p_i}) ; On-chain update
return result, $sbt_{p_i};$

2) MRT registration

Once p_i has been issued sbt_{p_i} they can interact with the marketplace, m_i . p_i sends sbt_{p_i} to m_i to verify their identity and KYC status. Initially, m_i provides p_i with a default MRT, mrt_{p_i} , with reputation level 0, stored in p_i 's wallet, w_{p_i} . After meeting the necessary criteria, p_i can request a re-evaluation of mrt_{p_i} by m_i . The criteria for different reputation levels were outlined in the previous subsection. m_i verifies sbt_{p_i} and updates mrt_{p_i} to reflect p_i 's assessed reputation score. The updated details of mrt_{p_i} are recorded on the blockchain. Any changes to mrt_{p_i} are also updated on the blockchain, ensuring a transparent and current record of p_i 's marketplace reputation. This process is depicted in Algorithm 2.

Algorithm 2: MRT registration

Input: p_i, m_i, sbt_{p_i} **Output:** $result, mrt_{p_i}$
 $data = [], result = True, False;$
 $data = receiveData(sbt_{p_i}, [mrt_{p_i}])$; m_i receives SBT and MRT (optional)
while $data$ **do**
 $result = verify(data)$; Verif. SBT, reput.
 if $result$ **then**
 $mrt_{p_i} = updateMRT(p_i)$; Issue/upd. MRT
 end
 return False;
end
 $register(mrt_{p_i})$; On-chain update
return $result, mrt_{p_i}$;

3) Trading initialization

Participants p_i and p_j , wishing to trade as outlined in Algorithm 3, are registered with marketplace m_i and have MRTs, mrt_{p_i} and mrt_{p_j} . Their trades occur through an off-chain state channel $SC_{p_{ij}}$, allowing real-time execution without on-chain delays. To use this, p_i and p_j must coordinate with m_i to ensure necessary collateral.

The process starts with p_j sending a transaction proposal to m_i , outlining trade terms and details. m_i verifies p_j 's mrt_{p_j} and collateral. If sufficient, m_i lists the transaction on the marketplace. p_i sets new trade requirements and receives a list of available trades, reviewing these proposals to assess the risk. If p_i decides to proceed, they send a reservation request to m_i with trade terms and details. m_i verifies p_i 's mrt_{p_i} and collateral. Upon confirmation, m_i forwards the reservation request to p_j . Subsequently, p_j and p_i establish the off-chain state channel $SC_{p_{ij}}$. Initial transactions may require identity or reputation verification through SBTs. For ongoing transactions, periodic verification of identities via DIDs ensures consistent authentication and meets legal KYC requirements. Verification against a revocation list is also feasible. Once $SC_{p_{ij}}$ is established, p_i and p_j can proceed with the trade, ensuring atomicity of transactions to reduce one-sided failures. The information within the state channel is encrypted and accessible only to p_i and p_j . The initiation of $SC_{p_{ij}}$ is recorded at m_i and on the blockchain to prevent misconduct, such as intentional locking of funds. Any such behavior negatively impacts participants' reputation.

Algorithm 3: Trading initialization

Input: $p_i, p_j, m_i, mrt_{p_i}, mrt_{p_j}$ **Output:** $result, SC_{p_{ij}}$
 $data, trade = [], []$; $result = True, False$;
 $trade = createTrade(data, p_i, p_j, mrt_{p_i}, mrt_{p_j})$; m_i receives trade details
 $result = verify(data)$; Ver. trade details
if $result$ **then**
 p_i, p_j lock collateral in m_i ; p_i, p_j initialize state channel $SC_{p_{ij}}$; registerTrade($trade$) ; On-chain update
 while $trade$ **do**
 Trade atomically off-chain in $SC_{p_{ij}}$;
 end
end
return False; **return** $result, SC_{p_{ij}}$;

4) Trade finalization

After p_i and p_j complete their trade, they finalize the transaction by verifying details and agreeing to the terms, as detailed in Algorithm 4. Both parties must consent to the final trade state and sign off on the transaction. This final state is recorded on the blockchain, and any remaining collateral is returned to p_i and p_j .

Dispute resolution, managed by m_i , can be initiated by either party and resolved on-chain or off-chain. SBTs act as proof of identity and reputation, providing valuable context during arbitration. The immutable nature of SBTs and MRTs ensures a secure transaction history and reputation audit trail, aiding dispute resolution. Outcomes, including any dispute resolutions, are recorded on the blockchain, updating participants' reputations (mrt_{p_i} and mrt_{p_j}).

Algorithm 4: Trading finalization

Input: $p_i, p_j, SC_{p_{ij}}, result$ **Output:** mrt_{p_i}, mrt_{p_j}
 $data, state = [], []$; $result = True, False$;
 $result, data, state = finalizeTrade(SC_{p_{ij}})$; m_i receives trade details
if $result$ **then**
 p_i, p_j sign final state; **if** $data == "dispute"$ **then**
 $result = verify(sbt_{p_i}, sbt_{p_j})$; Ver. identity
 m_i settles dispute based on $result$;
 $register(mrt_{p_i})$; On-chain update
 end
 $releaseCollateral(p_i, p_j)$; On-chain update
 $mrt_{p_i} = updateMRT(p_i)$; Issue/update MRT
 $mrt_{p_j} = updateMRT(p_j)$; Issue/update MRT
end
return False;

D. Revocation

SBTs can be revoked by the user or the issuing CA at any point, as outlined in Algorithm 5. Significant updates, like a name change, require re-verification and re-issuance. To mitigate security risks, the issuer may initiate a new KYC process. Non-critical information updates, like email addresses or phone numbers, can be made by the user unless used for

MFA, which requires third-party verification. If access to a private key is lost, accounts must be re-verified. To block access to a verified SBT, issuers add the account to a smart contract revocation list. This list can become large and costly to verify. A practical solution involves binding active accounts to a specific period with an identifier token updated when credentials are revoked. This method, suggested by [22], saves costs and reduces verification processes, ensuring a revoked account cannot present a valid KYC status. Similarly, MRTs can be revoked by m_i based on a revocation list, for example, if an account's reputation deteriorates. The marketplace manages this list. Under the proposed system, users can ascertain the KYC status and MRT level of other participants, whether transactions are conducted on- or off-chain.

Algorithm 5: Revocation

Input: $sbt_{p_i}, mrt_{p_i}, reason$ **Output:** $revocationList$
 $revocationList = []$; $result = \text{True}, \text{False}$;
 $result = \text{verify}(sbt_{p_i}, mrt_{p_i})$; Verify
identities
if $reason == \text{"Update to } sbt_{p_i}\text{"}$ **then**
 User requests re-verification and SBT re-issuance;
 Start process: SBT registration based on sbt_{p_i} ;
else if $reason == \text{"Update to } mrt_{p_i}\text{"}$ **then**
 Start process: MRT registration based on mrt_{p_i} ;
 $mrt_{p_i} = \text{issue}(mrt_{p_i})$;
else
 Add sbt_{p_i} or mrt_{p_i} to $revocationList$; Update
 $revocationList$ on-chain;
end
return $revocationList$;

E. Zero-Knowledge Proofs

ZKPs are used to demonstrate knowledge of a secret without revealing the secret itself. We use ZKPs to verify possession of SBTs and MRTs without disclosing the actual tokens, proving KYC or reputation levels without revealing identities. Common ZKPs include SNARKs, STARKs, SNORKs, and DARKs. The paper is neutral on the choice of ZKP, requiring only high security and verifiability both on- and off-chain.

The ZKP process has three stages: *Setup*, *Proof*, and *Verify* [33], [23]. The *Setup* stage $(k_\pi, k_\nu) \leftarrow \text{Setup}(S, 1^\lambda)$ generates the proof key k_π and the verification key k_ν for an algorithm S with security parameter λ . The *Proof* stage $\pi \leftarrow \text{Proof}(k_\pi, \mathbf{x}, \mathbf{w})$ produces the proof π showing that the prover $\mathcal{P}$ knows the secret, using the proof key k_π , the public input $\mathbf{x}$, and the private witness $\mathbf{w}$. The *Verify* stage $\nu \leftarrow \text{Verify}(k_\nu, \mathbf{x}, \pi)$ validates the proof π using the verification key k_ν , the public input $\mathbf{x}$, and the proof π . Verification is successful if $\nu = 1$ and fails if $\nu = 0$. The *Setup* stage is performed once, while *Proof* and *Verify* are executed for each transaction. Some ZKPs, like zk-STARKs, do not require a *Setup* stage and can directly proceed to *Proof* and *Verify* [34].

In previous sections, SBTs and MRTs serve as the private witness $\mathbf{w}$, and the transaction's timestamp acts as the public input $\mathbf{x}$. The proof key k_π and verification key k_ν are produced

by $\mathcal{P}$ or $\mathcal{V}$, respectively. For example, in SBT registration, $p_i \in \mathcal{P}$ generates k_π , while $ca_i \in \mathcal{V}$ generates k_ν . The proof π is calculated as follows: $\pi \leftarrow \text{Proof}(k_\pi, \text{timestamp}, \text{SBT})$.

Here, the timestamp is the public input, and the SBT is the private input, such as KYC or reputation level. Range proofing shows that the element lies within a specific range (e.g. 0-3 for KYC or reputation level). It verifies that the SBT or MRT is valid, not revoked, and exceeds the required verification level.

The smart contract containing the ZKP is deployed on-chain. Proof π and timestamp, along with a commitment, are submitted to the contract. The state of p_i is updated to confirm the transaction. Since transactions are public, others can confirm the proof's correctness using: $\text{True} \mid \text{False} \leftarrow \text{Verify}(k_\nu, \text{timestamp}, \pi)$.

IV. EVALUATION

A. Threat model

Prover $\mathcal{P}$ aims to demonstrate to verifier $\mathcal{V}$ that they possess a witness $\mathbf{w}$ for a statement $\mathbf{y} = S(\mathbf{x}, \mathbf{w})$, where S is an algorithm and $\mathbf{x}$ is the input. The threat model involves a malicious adversary $\mathcal{M}$, who has access to both $\mathcal{P}$ and $\mathcal{V}$ and seeks to discover the witness $\mathbf{w}$. $\mathcal{M}$ has the same computational capabilities as $\mathcal{P}$ and $\mathcal{V}$ and can perform all their operations. $\mathcal{M}$ disregards protocol steps to extract information about $\mathbf{w}$. The system is designed to prevent $\mathcal{M}$ from compromising the soundness and zero-knowledge properties, even if they bypass protocol steps. If $\mathcal{P}$ follows the protocol correctly, $\mathcal{V}$ will validate the proof with high probability, ensuring soundness. $\mathcal{V}$ learns only the truth of the statement $\nu = S(\mathbf{x}, \mathbf{w})$ without gaining any private information. If $\mathcal{M}$ fails to learn $\mathbf{w}$, the scheme retains its zero-knowledge property. Additionally, $\mathcal{M}$ must not be able to reuse proofs, preserving the non-transferability characteristic. Furthermore, $\mathcal{M}$ could try to access or alter the IPFS, compromising data integrity and privacy. To prevent this, data access within smart contracts is restricted, and data storage is encrypted. Integrity is protected through blockchain's innate capabilities. $\mathcal{M}$ could also attempt to manipulate SBTs or MRTs, gaining unauthorized access or altering reputation scores. By using decentralized identity verification methods and cross-verifying information from multiple CAs or marketplaces, the risk of unauthorized access is minimized. Selective sharing of verification processes with third parties, approved by the data owner, also helps. Hierarchical reputation scoring incentivizes transparency and discourages malicious behaviour.

B. Security Analysis

A malicious actor $\mathcal{M}$ with significant financial resources might try to influence SBT or MRT issuance to gain reputation within a marketplace without fulfilling requirements. Implementing the issuance process within a smart contract decentralizes control and reduces this risk. However, more public verifiable data in smart contracts increases privacy leakage risk. To mitigate this, data access within smart contracts must be restricted to authorized participants (e.g. with RBAC and digital signatures), preventing unauthorized access

and manipulation. This ensures system security and integrity, preventing unauthorized parties from accessing VCs within IPFS without keys. Another potential issue is the theft, forgery, or copying of tokens. Ensuring that NFTs for SBTs are non-transferable maintains token uniqueness and ownership integrity. However, a dishonest CA or marketplace might accept a false token, granting $\mathcal{M}$ system access. To prevent this, we must minimize incentives for dishonest behaviour, allow verification by multiple third parties, and ensure verification processes are transparent and verifiable by others. Validating smart contract security and integrity is essential. Additionally, selective sharing of verification processes with other third parties, approved by the data owner, helps. For this, we can use the CL scheme [52], enabling CAs or marketplaces to share part of the verification with others.

C. Privacy Analysis

In current systems, users must send their data to external parties, risking data breaches. Our scheme keeps data within the user's control, stored in IPFS, accessible only by the user and CA (issuer of the DID). This ensures data security and user control over sharing. Selective disclosure allows users to choose which data to disclose, requiring a permission model to prevent unauthorized access. KYC data needs regular checks and verification against a revocation list. If the CA is compromised, data can be leaked, and false SBTs/MRTs issued. Users can revoke CA access to VCs, and CAs can revoke compromised user SBTs. MRTs, linked to SBTs, should be regularly reverified by the marketplace and revoked if suspicious activity is detected. An additional risk is multiple SBTs in one wallet, potentially revealing user identity. A solution is to store SBTs in IPFS and keep only the SBT hash in the wallet. Selective disclosure allows the user to decide which SBT to disclose, and the hash verifies the SBT in IPFS.

D. Complexity Analysis

Table III illustrates the asymptotic complexity analysis, combining data from Table II and applied to the five algorithms presented earlier. The x-axis displays the input size complexity, total proof complexity (denoted by the symbol π), verifier complexity $\mathcal{V}$, prover complexity $\mathcal{P}$ and algorithm type. The y-axis lists the combined complexities of algorithms 1 to 5, annotated using Big-O notation.

SNARKs and SNORKs exhibit identical computational complexities for the total proof size π , the verifier $\mathcal{V}$, and the prover $\mathcal{P}$. Both have constant time complexity ($O(1)$) for the total proof size π . BP (Bulletproofs) has logarithmic complexity ($O(\log n)$) for verification and proof generation, which may pose scalability challenges for larger datasets or resource-constrained environments. STARKs include polylogarithmic factors, indicated by the Li symbol, maintaining succinctness and transparency without a trusted setup, unlike SNARKs [34]. DARKs share similar verifier complexity with SNARKs and SNORKs but have increased complexity in proof generation due to additional cryptographic mechanisms. The consistent $O(n)$ complexity across all algorithms for the input

size $f(n)$ shows a linear relationship between computation size and effort required. However, verifier and prover complexities vary. SNARKs and SNORKs offer constant verifier complexity, while BPs, STARKs, and DARKs have logarithmic or polylogarithmic complexities, indicating a trade-off between proof size and verification speed. Prover complexity $\mathcal{P}$, representing the effort to generate a proof π , is $O(n \log n)$ for most algorithms, except for STARKs and DARKs, which are tied to polylogarithmic terms, indicating that proof generation efficiency could be significantly impacted by input data size.

Algorithm Type	$f(n)$	π	$\mathcal{V}$	$\mathcal{P}$
SNARK/SNORK (Alg. 1, 2, 5)	$O(n^2)$	$O(1)$	$O(n)$	$O(n \log n)$
SNARK/SNORK (Alg. 3, 4)	$O(n)$	$O(1)$	$O(n)$	$O(n \log n)$
BP (Alg. 1, 2, 5)	$O(n^2)$	$O(n \log n)$	$O(n^2)$	$O(n \log n)$
BP (Alg. 3, 4)	$O(n)$	$O(\log n)$	$O(n)$	$O(n \log n)$
STARK (Alg. 1, 2, 5)	$O(n^2)$	$O(n Li n)$	$O(n Li n)$	$O(n^2 Li n)$
STARK (Alg. 3, 4)	$O(n)$	$O(Li n)$	$O(n)$	$O(n Li n)$
DARK (Alg. 1, 2, 5)	$O(n^2)$	$O(n \log n)$	$O(n \log n)$	$O(n^2 \log n)$
DARK (Alg. 3, 4)	$O(n)$	$O(n)$	$O(n)$	$O(n \log n)$

TABLE III: Asymptotic Complexity Analysis

V. RELATED WORK

The demand for privacy-preserving identity management and KYC solutions has spurred significant research into blockchain technology and SSI. These innovations empower individuals to control their personal data while ensuring compliance and security. ZKPs have proven effective in secure, verifiable identity authentication without compromising privacy. Abraham et al. [20] presented a revocable offline verifiable self-sovereign identity system using ZKPs for private authentication. Similarly, Aydar et al. [18] introduced a blockchain-based system for secure KYC data sharing across financial institutions. Further exploration has led to diverse KYC solutions tailored to specific regulatory requirements and blockchain platforms. TradeMap [21] meets FINMA-compliant KYC requirements, while Biryukov et al. [26] and Pauwels et al. [8] integrate KYC-compliant identity schemes into Ethereum and DeFi protocols, respectively. Anonymous credential schemes like ZEBRA [22] enable on-chain verification while preserving anonymity. Singh et al. [24] proposed a credential scheme for accessing services without revealing privacy-sensitive attributes, emphasizing user control over data sharing. Kim et al. [15] presented a digital authentication system integrating credentials with SBTs for KYC in the metaverse, using ZKPs for compliance and privacy. ZKPs also apply in domains like energy trading [23], and blockchain-based reputation systems, as proposed by Zhang et al. [25], evaluate trustworthiness in marketplaces. Our proposed scheme balances privacy, compliance, and decentralization in KYC processes. We use SBTs to link verified identities and reputation immutably, while ZKPs enable selective disclosure of necessary attributes, giving users control over their data and building trust in marketplace environments.

VI. CONCLUSIONS AND FURTHER WORK

In conclusion, this paper proposes a ZKP-enabled KYC scheme for collateralized marketplaces on DLT. The scheme employs SBTs for decentralized identity provisioning and regulatory compliance verification. We introduce MRTs for reputation management and incentivizing good conduct within marketplaces.

By linking decentralized identity with reputation scores, we significantly reduce the potential for attacks and malicious behaviour. ZKPs provide privacy-preserving mechanisms, allowing users to share only necessary information while maintaining control over their data, in line with SSI principles.

Future work can extend the scheme by exploring different ZKP mechanisms to reduce verification time and costs and to ensure post-quantum security. The proposed design can also be applied to other use cases, such as decentralized exchanges, lending protocols, and other DeFi applications. Additionally, the scheme can be expanded to include other data types, like credit scores and employment history, for a more comprehensive KYC process.

REFERENCES

- [1] W. Shao, H. Li, M. Chen, C. Jia, C. Liu, and Z. Wang, "Identifying Bitcoin Users Using Deep Neural Network," in *Algorithms and Architectures for Parallel Processing* (J. Vaidya and J. Li, eds.), vol. 11337, pp. 178–192.
- [2] S. Ghesmati, W. Fdhila, and E. Weippl, "SoK: How private is Bitcoin? Classification and Evaluation of Bitcoin Privacy Techniques," in *ARES* 22, pp. 1–14, ACM.
- [3] D. A. Tran, M. T. Thai, and B. Krishnamachari, eds., *Handbook on Blockchain*, vol. 194 of *Springer Optimization and Its Applications*. Springer International Publishing.
- [4] "Directive (EU) 2015/849."
- [5] "Directive (EU) 2018/843."
- [6] Financial Crimes Enforcement Network, "Anti-Money Laundering Act of 2020."
- [7] FATF, "Targeted update on implementation of the FATF standards on virtual assets and virtual asset service providers."
- [8] P. Pauwels, J. Pirovich, P. Braunz, and J. Deeb, "zkKYC in DeFi: An approach for implementing the zkKYC solution concept in Decentralized Finance," *Cryptology ePrint Archive*, Paper 2022/321.
- [9] J. Zhu, Z. Huang, Y. Xu, J. Yen, and Y. Wang, "Data Privacy Protection in DeFi Protocols."
- [10] D. Malhotra, P. Saini, and A. K. Singh, "How Blockchain Can Automate KYC: Systematic Review," vol. 122, no. 2, pp. 1987–2021.
- [11] UNDP, "United Nations Development Programme Digital Strategy 2022–2025."
- [12] J. Benet, "IPFS - Content Addressed, Versioned, P2P File System."
- [13] D. Trautwein, A. Raman, G. Tyson, I. Castro, W. Scott, M. Schubotz, B. Gipp, and Y. Psaras, "Design and evaluation of IPFS: A storage layer for the decentralized web," in *Proceedings of the ACM SIGCOMM 2022 Conference*, pp. 739–752, ACM.
- [14] E. G. Weyl, P. Ohlhaber, and V. Buterin, "Decentralized Society: Finding Web3's Soul."
- [15] G. Kim and J. Ryou, "Digital Authentication System in Avatar Using DID and SBT," vol. 11, no. 20, p. 4387.
- [16] M. Sporny, D. Longley, M. Sabadello, D. Reed, O. Steele, and C. Allen, "Decentralized Identifiers (DIDs) v1.0."
- [17] P. Pettinari, P. Wackerow, and N. Quiroz, "Non-fungible tokens (NFT)."
- [18] M. Aydar, S. Ayyaz, and S. C. Cetin, "Towards a Blockchain based digital identity verification, record attestation and record sharing system."
- [19] P. L. Juhász, J. Stéger, D. Kondor, and G. Vattay, "A Bayesian approach to identify Bitcoin users," vol. 13, no. 12, p. e0207000.
- [20] A. Abraham, S. More, C. Rabensteiner, and F. Hörandner, "Revocable and Offline-Verifiable Self-Sovereign Identities," in *2020 IEEE 19th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pp. 1020–1027, IEEE.
- [21] S. R. Niya, S. Allemann, A. Gabay, and B. Stiller, "TradeMap: A FINMA-compliant Anonymous Management of an End-2-end Trading Market Place," in *2019 15th International Conference on Network and Service Management (CNSM)*, pp. 1–5, IEEE.
- [22] D. Rathee, G. V. Policharla, T. Xie, R. Cottone, and D. Song, "ZEBRA: Anonymous credentials with practical on-chain verification and applications to KYC in DeFi," *Cryptology ePrint Archive*, Paper 2022/1286.
- [23] D. Hou, J. Zhang, S. Huang, Z. Peng, J. Ma, and X. Zhu, "Privacy-Preserving Energy Trading Using Blockchain and Zero Knowledge Proof," in *2022 IEEE International Conference on Blockchain (Blockchain)*, pp. 412–418, IEEE.
- [24] K. Singh, O. Dib, C. Huyart, and K. Toumi, "A novel credential protocol for protecting personal attributes in blockchain," vol. 83, p. 106586.
- [25] P. Zhang, P. Wu, Y. Liu, Y. Chen, Y. Li, J. Yan, and M. Ghafouri, "Toward a Blockchain-Based, Reputation-Aware Secure Transactive Energy Market," vol. 2, no. 1, pp. 61–78.
- [26] A. Biryukov, D. Khovratovich, and S. Tikhomirov, "Privacy-preserving KYC on Ethereum."
- [27] DIF, "DIF - Decentralized Identity Foundation."
- [28] "Regulation (EU) 2016/679."
- [29] F. Hendriks, K. Bubendorfer, and R. Chard, "Reputation systems: A survey and taxonomy," vol. 75, pp. 184–197.
- [30] T. Wang, J. Guo, S. Ai, and J. Cao, "RBT: A distributed reputation system for blockchain-based peer-to-peer energy trading with fairness consideration," vol. 295, p. 117056.
- [31] M. H. Ullah and J.-D. Park, "Peer-to-Peer Energy Trading in Transactive Markets Considering Physical Network Constraints," vol. 12, no. 4, pp. 3390–3403.
- [32] M. Drgon, L. Georgiou, and A. Kiayias, "Securing DLT-based KYC via randomised audits," vol. 6, no. 2, pp. 181–192.
- [33] D. Mouris and N. G. Tsoutsos, "Zilch: A Framework for Deploying Transparent Zero-Knowledge Proofs," vol. 16, pp. 3269–3284.
- [34] E. Ben-Sasson, I. Bentov, Y. Horeh, and M. Riabzev, "Scalable, transparent, and post-quantum secure computational integrity."
- [35] A.-E. Panait and R. F. Olimid, "On Using zk-SNARKs and zk-STARKs in Blockchain-Based Identity Management," in *Innovative Security Solutions for Information Technology and Communications* (D. Maimut, A.-G. Oprina, and D. Sauveron, eds.), vol. 12596, pp. 130–145, Springer International Publishing.
- [36] B. Bünz, B. Fisch, and A. Szeipieniec, "Transparent SNARKs from DARK Compilers," in *Advances in Cryptology – EUROCRYPT 2020* (A. Canteaut and Y. Ishai, eds.), vol. 12105, pp. 677–706, Springer International Publishing.
- [37] B. Bünz, B. Fisch, and A. Szeipieniec, "Transparent SNARKs from DARK Compilers."
- [38] M. Maller, S. Bowe, M. Kohlweiss, and S. Meiklejohn, "Sonic: Zero-Knowledge SNARKs from Linear-Size Universal and Updatable Structured Reference Strings."
- [39] A. Gabizon, Z. J. Williamson, and O. Ciobotaru, "PlonK: Permutations over Lagrange-bases for Oecumenical Noninteractive arguments of Knowledge."
- [40] A. Chiesa, Y. Hu, M. Maller, P. Mishra, P. Vesely, and N. Ward, "Marlin: Preprocessing zkSNARKs with Universal and Updatable SRS."
- [41] J. Groth, "On the Size of Pairing-Based Non-interactive Arguments," in *Advances in Cryptology – EUROCRYPT 2016* (M. Fischlin and J.-S. Coron, eds.), vol. 9666, pp. 305–326, Springer Berlin Heidelberg.
- [42] H. Lipmaa, "On Diophantine Complexity and Statistical Zero-Knowledge Arguments," in *Advances in Cryptology - ASIACRYPT 2003* (C.-S. Lai, ed.), vol. 2894, pp. 398–415, Springer Berlin Heidelberg.
- [43] E. Ben-Sasson, I. Bentov, Y. Horeh, and M. Riabzev, "Scalable Zero Knowledge with No Trusted Setup," in *Advances in Cryptology – CRYPTO 2019* (A. Boldyreva and D. Micciancio, eds.), vol. 11694, pp. 701–732, Springer International Publishing.
- [44] Matter Labs, "Awesome zero knowledge proofs (zkp)."
- [45] B. Bunz, J. Bootle, D. Boneh, A. Poelstra, P. Wuille, and G. Maxwell, "Bulletproofs: Short Proofs for Confidential Transactions and More," in *2018 IEEE Symposium on Security and Privacy (SP)*, pp. 315–334, IEEE.
- [46] T. Neudecker and H. Hartenstein, "Network Layer Aspects of Permissionless Blockchains," vol. 21, no. 1, pp. 838–857.
- [47] A. Mohaisen and J. Kim, "The Sybil Attacks and Defenses: A Survey,"
- [48] S. Zhang and J.-H. Lee, "Double-Spending With a Sybil Attack in the Bitcoin Decentralized Network," vol. 15, no. 10, pp. 5715–5722.
- [49] J. Leng, M. Zhou, J. L. Zhao, Y. Huang, and Y. Bian, "Blockchain Security: A Survey of Techniques and Research Directions," vol. 15, no. 4, pp. 2490–2510.
- [50] J. R. Douceur, "The Sybil Attack," in *Peer-to-Peer Systems* (P. Druschel, F. Kaashoek, and A. Rowstron, eds.), vol. 2429, pp. 251–260, Springer Berlin Heidelberg.
- [51] M. Lodder and D. Khovratovich, "Anonymous credentials 2.0."
- [52] J. Camenisch and A. Lysyanskaya, "A Signature Scheme with Efficient Protocols," in *Security in Communication Networks* (S. Cimato, G. Persiano, and C. Galdi, eds.), vol. 2576, pp. 268–289, Springer Berlin Heidelberg.